



POLITIQUE DE SÉCURITÉ

Cours 1



Dr. Sarra Namane

Département d'informatique

Université Badji Mokhtar, Annaba

Promotion: Master 1 (RSI)

Année: 2024/2025

Introduction

- La connexion croissante des différents domaines à Internet a considérablement amplifié les enjeux en matière de sécurité informatique.
- L'intensification de la vulnérabilité des systèmes informatiques à des attaques cybernétiques.
- La nécessité de renforcer les mesures de sécurité.
- Adopter des politiques de gestion des risques et promouvoir une culture de la cybersécurité devient impérative pour atténuer les menaces émergentes dans un monde de plus en plus interconnecté.

La santé



L'énergie



Internet



Les infrastructure critiques



L'éducation

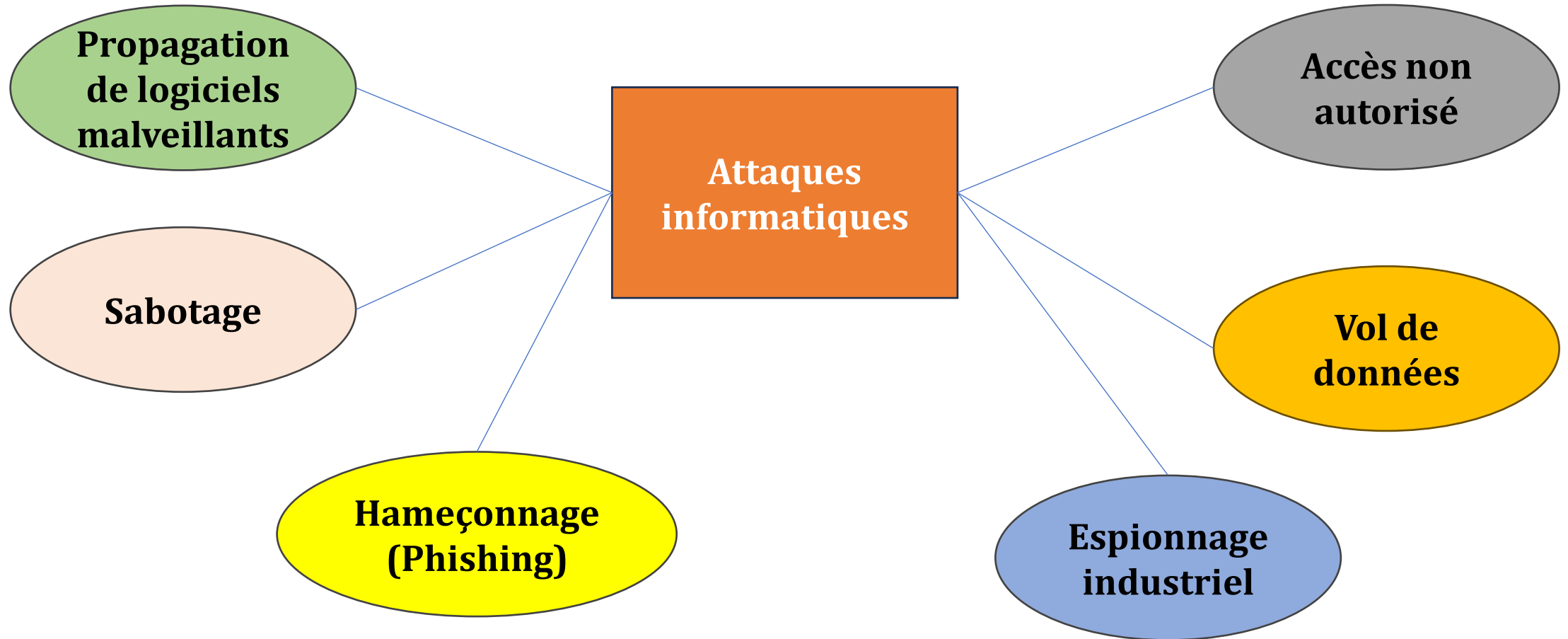
la connectivité accrue offre des avantages indéniables en termes de communication et d'efficacité



Exposition des différents secteurs à des risques significatifs (attaques informatiques)

Introduction (2)

Les motivations des attaquants peuvent varier, allant de la simple curiosité et de l'exploration à des motivations financières, politiques ou idéologiques.



Introduction (3)

La prévention et la protection contre les attaques informatiques sont des enjeux cruciaux pour assurer **la sécurité informatique**.

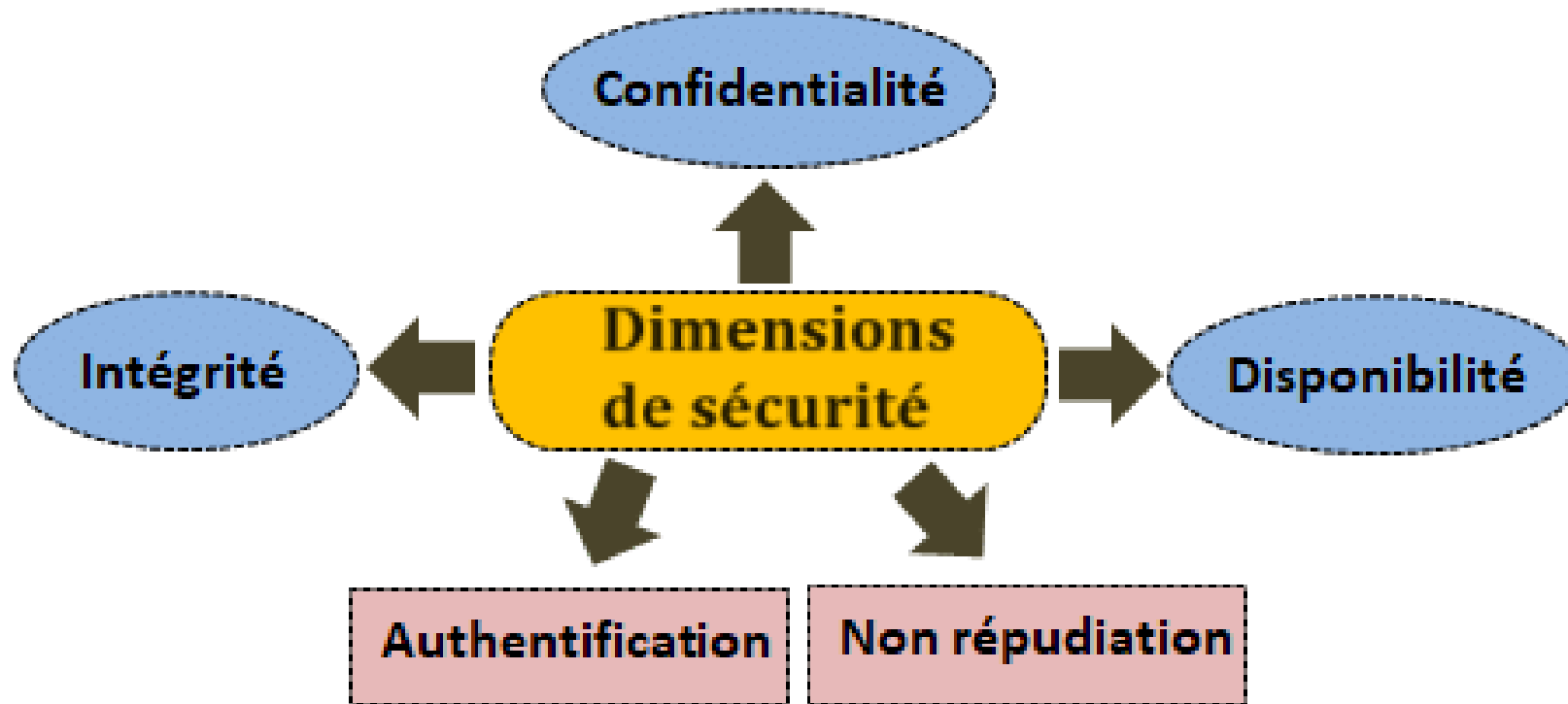
Qu'est ce que la sécurité informatique?

La sécurité informatique englobe l'ensemble des mesures et des pratiques mises en place pour protéger les systèmes informatiques, les réseaux, les données et les services contre les menaces intentionnelles ou accidentelles.



Les dimensions de sécurité

Une **dimension de sécurité** se réfère à un aspect spécifique ou à une caractéristique particulière qui doit être prise en compte dans le cadre d'une approche globale de la protection contre les menaces et les risques.



Les dimensions de sécurité (2)

L'authentification

L'authentification est le processus par lequel un système vérifie l'identité d'un utilisateur, d'un appareil ou d'une entité. Elle vise à garantir que la personne ou l'élément prétendant être ce qu'il prétend être est effectivement légitime.



Les dimensions de sécurité (3)

Les facteurs d'authentification

Les facteurs d'authentification sont classés en trois catégories principales :

1. Facteur de Connaissance :

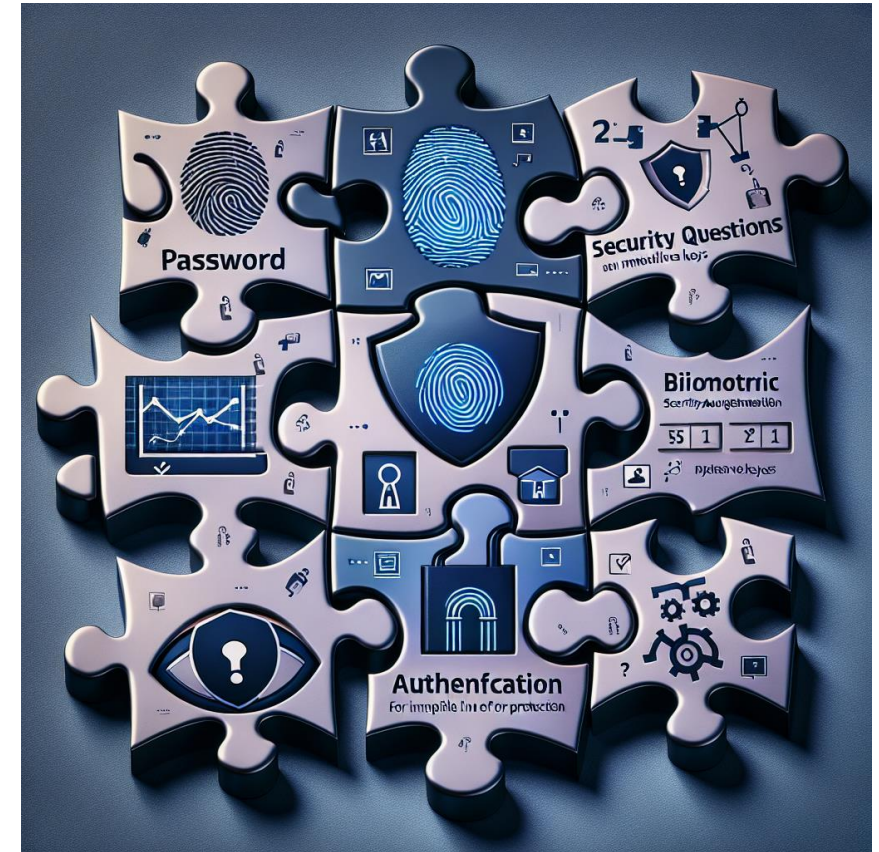
- **Mots de passe** : Combinaisons de caractères secrètes connues de l'utilisateur.
- **Codes PIN** : Nombres à chiffres limités, également connus de l'utilisateur.
- **Signatures** : Une méthode où l'utilisateur démontre sa capacité à reproduire une signature spécifique.

2. Facteur de Possession :

- **Cartes à puce** : Cartes électroniques contenant des informations d'identification.
- **Jetons de sécurité** : Dispositifs générant des codes temporaires.

3. Facteur d'Inhérence :

- **Empreintes digitales** : Caractéristiques physiques uniques du corps.
- **Reconnaissance faciale** : Identification basée sur les traits du visage.
- **Iris ou rétine** : Utilisation de caractéristiques oculaires.



Les méthodes d'authentification à plusieurs facteurs (MFA) combinent deux ou plusieurs de ces éléments pour renforcer la sécurité en exigeant plusieurs formes de vérification avant d'autoriser l'accès.

Les dimensions de sécurité (4)

Les phases d'authentification

L'identification

L'identification consiste à fournir
un identifiant

L'authentification

L'authentification vérifie l'identité

L'autorisation

L'autorisation détermine les actions
permises une fois l'identité
confirmée

Les dimensions de sécurité (5)

La confidentialité

- La confidentialité en cybersécurité fait référence à la protection des informations sensibles contre l'accès ou la divulgation non autorisés.
- Cela implique la mise en place de mesures pour garantir que les données ne sont accessibles qu'aux personnes autorisées à les consulter ou à les manipuler.
- Cela peut inclure le **chiffrement**, les **contrôles d'accès** et les **protocoles de communication sécurisés** pour protéger les données contre toute compromission.

La confidentialité est un **aspect fondamental** de la cybersécurité, en particulier lorsqu'il s'agit d'informations personnelles, financières ou propriétaires

Les dimensions de sécurité (6)

L'intégrité

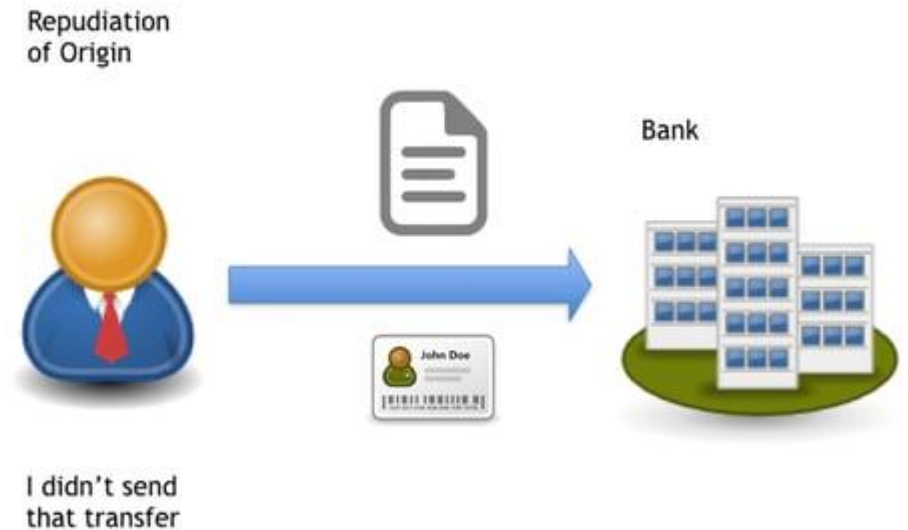
- L'intégrité en cybersécurité se réfère à la garantie que **les données** et les systèmes informatiques demeurent **intacts, non altérés** et **fiables**.
- Cela signifie qu'il n'y a pas eu de modification non autorisée des données, du code source, des configurations système ou d'autres éléments critiques.
- Les mécanismes d'intégrité, tels que les fonctions de hachage cryptographique, sont utilisés pour détecter toute altération indésirable.

Assurer l'intégrité des informations **est crucial** pour prévenir les attaques visant à altérer ou corrompre les données, ce qui pourrait entraîner des **conséquences graves** en matière de sécurité.

Les dimensions de sécurité (7)

La non-répudiation

La non-répudiation en cybersécurité fait référence à la capacité à prouver qu'une personne a bien envoyé un message ou effectué une action, et à empêcher cette personne de nier ultérieurement son implication. Cela garantit l'authenticité et la fiabilité des transactions électroniques.



Les dimensions de sécurité (8)

La Disponibilité

La disponibilité en cybersécurité fait référence à la capacité des systèmes informatiques à être **accessibles** et utilisables lorsque nécessaire, tout en étant protégés contre les interruptions ou les attaques.

Cela implique de garantir que les ressources et les données sont **disponibles** pour les utilisateurs légitimes et que les services informatiques ne sont **pas perturbés** par des cyberattaques ou des pannes.

Vulnérabilité

Une vulnérabilité en cybersécurité est **une faiblesse** ou une lacune dans un système informatique qui **peut être exploitée** par des attaquants pour compromettre l'intégrité, la confidentialité ou la disponibilité des données.



LES FACTEURS DE VULNÉRABILITÉ

01

Erreurs de programmation

Des erreurs dans le code source des logiciels peuvent créer des failles de sécurité exploitées par des attaquants.

02

Mauvaises pratiques de développement

L'utilisation de pratiques de développement non sécurisées peut entraîner des vulnérabilités.

03

Manque de mises à jour

Ne pas appliquer régulièrement les correctifs de sécurité expose les systèmes aux vulnérabilités connues.

04

Faiblesse des mots de passe

L'utilisation de mots de passe faibles ou leur stockage non sécurisé peut rendre les comptes facilement compromis.

05

Absence de chiffrement

Le manque de chiffrement des données pendant leur transit ou au repos peut conduire à des fuites d'informations sensibles.

Attaque

- Une attaque informatique est une action intentionnelle visant à compromettre, perturber, ou obtenir un accès non autorisé à un système informatique, à des données sensibles ou à des ressources numériques.
- Ces attaques sont souvent menées par des individus ou des groupes malveillants, tels que des pirates informatiques, des cybercriminels ou des acteurs étatiques, dans le but de causer des dommages, de voler des informations confidentielles, d'extorquer de l'argent ou de compromettre la sécurité d'une organisation ou d'un individu.



Les attaques passives

Une attaque **passive** est une attaque où l'attaquant ne modifie pas directement ou n'interfère pas avec les données ou les systèmes ciblés. Au lieu de cela, l'attaquant observe simplement les informations qui transitent à travers le réseau ou qui sont stockées sur un système sans perturber leur fonctionnement normal.

01

Analyse
du trafic

02

Capture du
contenu de
message

L'objectif principal d'une attaque passive est généralement d'espionner ou de recueillir des informations sensibles, telles que des mots de passe, des données financières, des communications confidentielles ou des schémas de trafic réseau, dans le but de les utiliser ultérieurement pour des activités malveillantes.

Une attaque active, en revanche, implique une intervention directe de l'attaquant pour altérer, endommager ou compromettre les données ou les systèmes ciblés. Contrairement à une attaque passive, une attaque active vise à perturber ou à manipuler le fonctionnement normal des systèmes ou des processus informatiques.

Les attaques actives

01
SPOOFING

02
REJEU

03
**DENI DE
SERVICE**

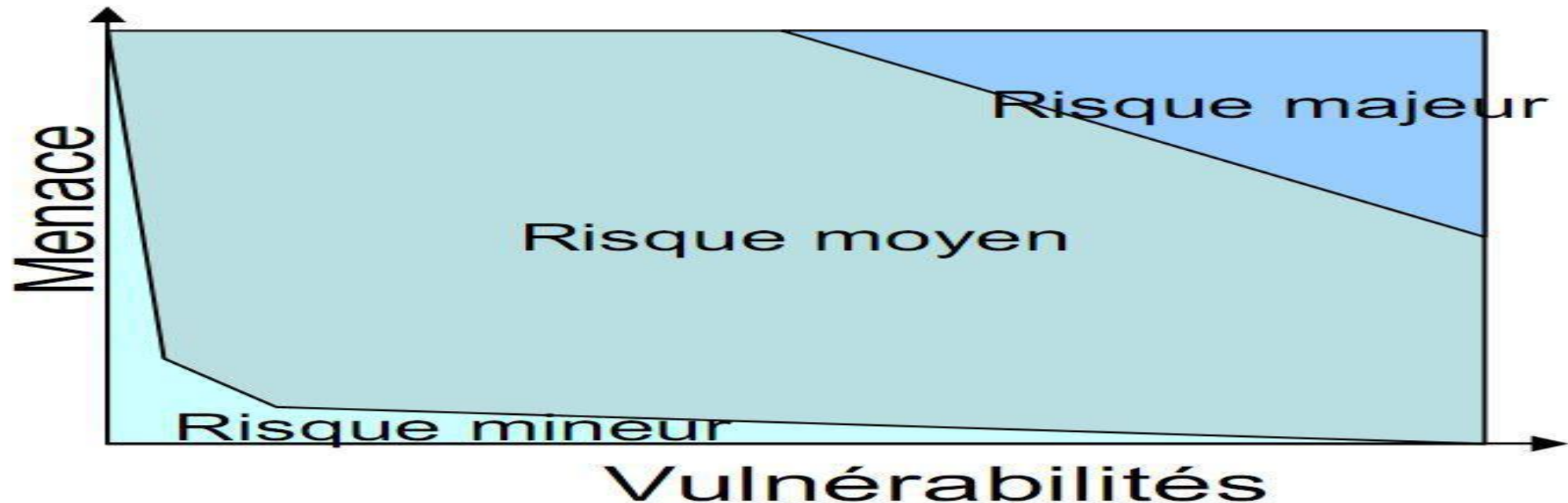
04
**L'HOMME
DU MILIEU**

Risque

Danger, inconvénient possible

Peut être désigné comme le risque «métier» associé à l'utilisation, la possession, l'exploitation, l'implication, l'influence et l'adoption de l'informatique dans une organisation.

$$\text{Risque} = \text{Vulnérabilité} + \text{menace/contre-mesure}$$



Techniques et mécanismes pour sécuriser un système

01

Mécanisme de sécurité cryptographique

02

Détection d'intrusion

03

Les pare-feux

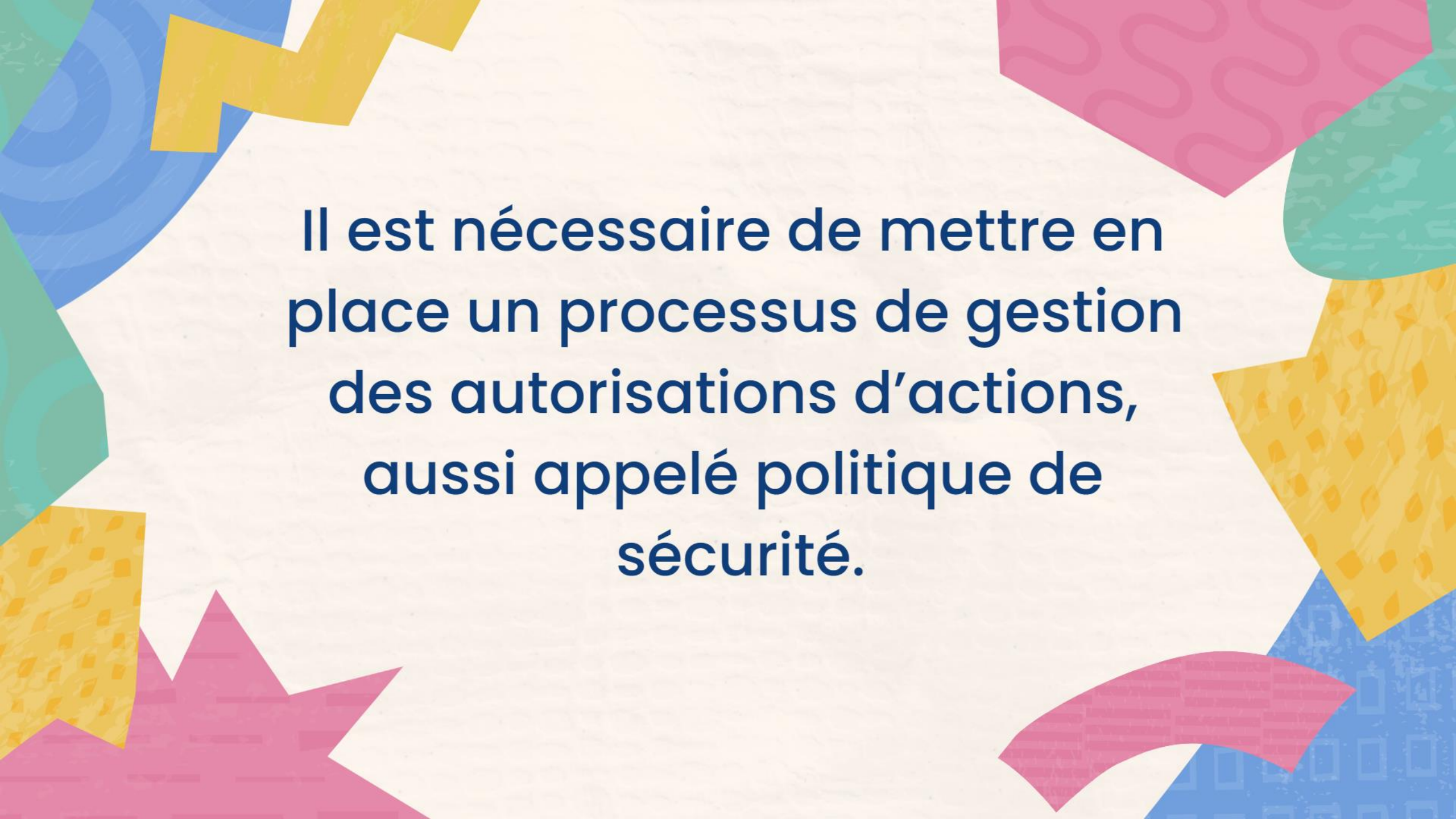
04

Les politiques de sécurité



POLITIQUE DE SECURITE

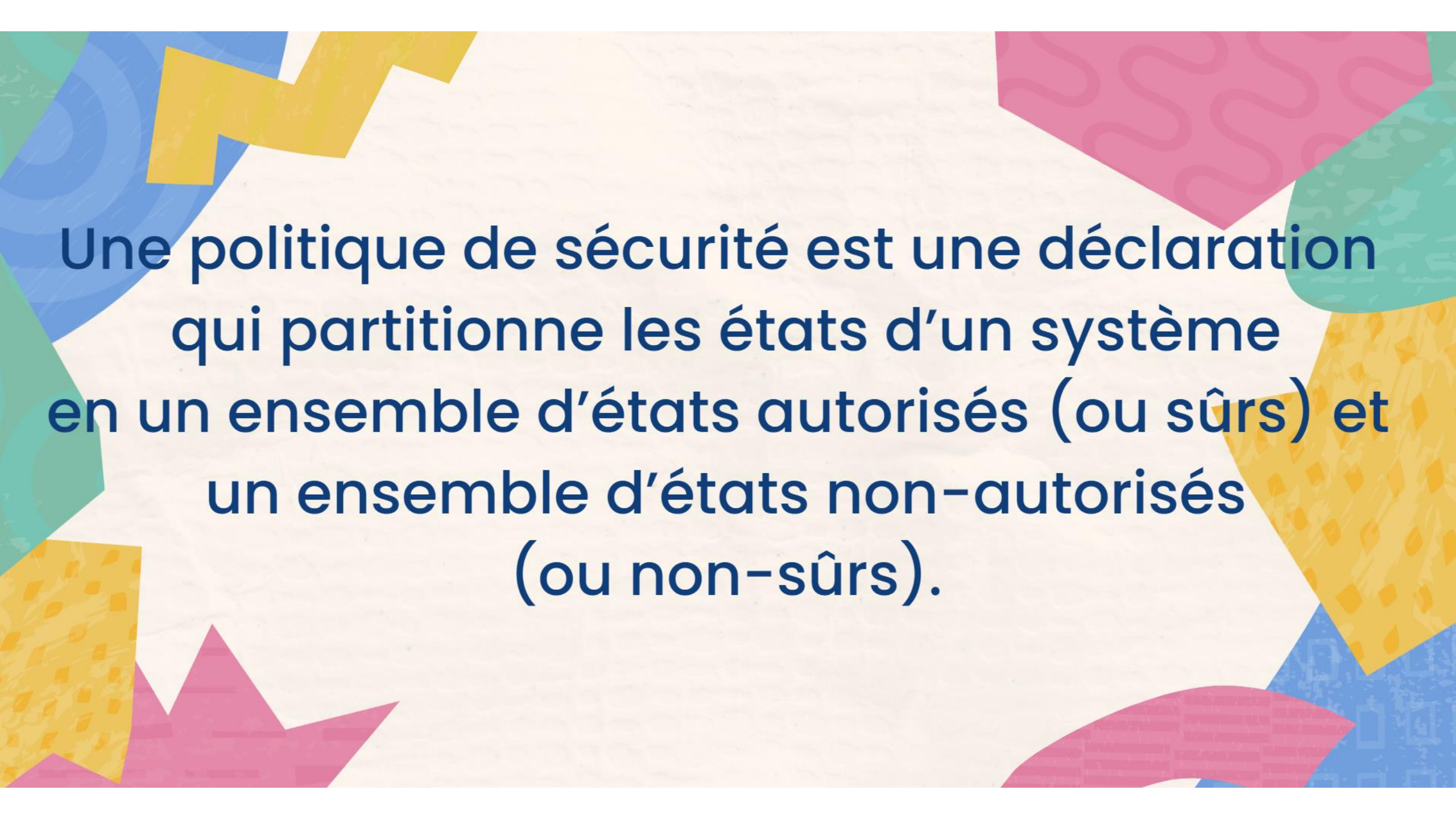
- Afin d'assurer un niveau de sécurité adéquat, il est impératif de restreindre les actions des utilisateurs sur le système.
- Les droits d'accès et les permissions doivent varier en fonction du statut ou du niveau de confiance attribué à chaque utilisateur.
- Par exemple, dans le contexte des applications médicales, où les données échangées sont hautement sensibles, toute fuite d'information doit être rigoureusement évitée. Cependant, en cas d'urgence médicale, restreindre l'accès à ces informations vitales pourrait mettre des vies en danger. Ainsi, les lois exigent que les entreprises mettent en place des mécanismes robustes pour répondre à ces impératifs de sécurité dans leurs systèmes informatiques et leurs services Web, tout en tenant compte des spécificités de chaque situation et des droits d'accès appropriés pour chaque utilisateur.

The background features several large, overlapping geometric shapes in various colors: blue, yellow, pink, and teal. These shapes have different patterns, including concentric circles, wavy lines, and small squares. The text is centered in a dark blue, sans-serif font.

Il est nécessaire de mettre en place un processus de gestion des autorisations d'actions, aussi appelé politique de sécurité.

Qu'est ce qu'une politique de sécurité ?

- L'ensemble des **lois, règles** et **pratiques** qui régissent la façon dont l'information sensible et les autres ressources sont gérées, protégées et distribuées à l'intérieur d'un système spécifique.
- Un **document de référence** permettant de décrire les mesures élémentaires de protection et d'utilisation du système d'information afin que tout le monde puisse les respecter.
- Un **document de référence** définissant les **objectifs** à atteindre et les moyens accordés pour y parvenir.
- Constitue un **ensemble de règles** qui définissent les dimensions de sécurité souhaitées pour chaque paquet en fonction de certains attributs tels que le protocole de sécurité, l'adresse source et l'adresse de destination.

The background features several overlapping geometric shapes in various colors: a large yellow shape at the top left, a pink shape at the top right, a blue shape at the bottom left, and a yellow shape at the bottom right. There are also smaller shapes in shades of green and pink. The shapes have different patterns, some solid and some with a grid or wavy texture.

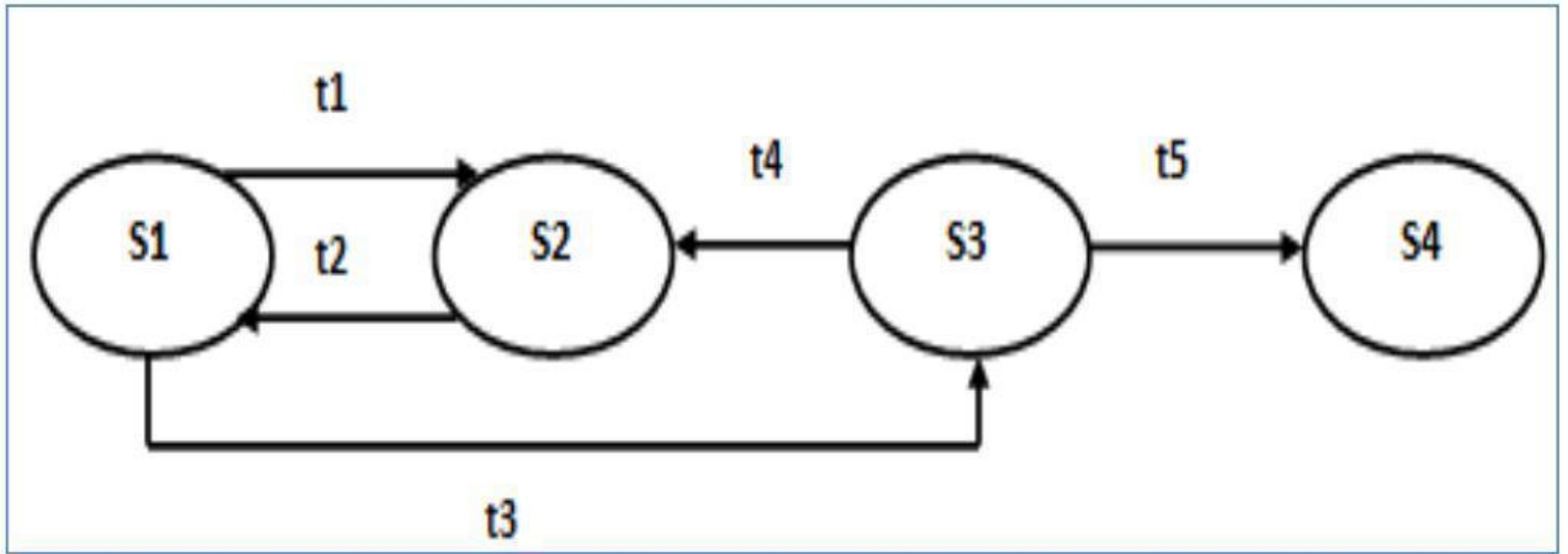
Une politique de sécurité est une déclaration
qui partitionne les états d'un système
en un ensemble d'états autorisés (ou sûrs) et
un ensemble d'états non-autorisés
(ou non-sûrs).

Définition d'un système sûr

Un système sûr est un système qui, partant d'un état sûr, ne pourra jamais entrer dans un état non-sûr.

EXEMPLE:

Considérons l'automate suivant contenant quatre états et cinq transitions, représentant un système. Prenons l'exemple d'une politique de sécurité qui partitionne ce système en un ensemble d'états autorisés $A = \{s1, s2\}$ et un ensemble d'états non-autorisés $NA = \{s3, s4\}$.



Une brèche de sécurité apparaît lorsqu'un système entre dans un état non-autorisé.

$A = \{s1, s2\}$

$NA = \{s3, s4\}$

En 1991, Sterne a établi que toute définition d'une politique de sécurité doit pouvoir identifier les aspects fondamentaux suivants :

- **Objectif de sécurité** : Il exprime l'intention de protéger une ressource spécifique contre une utilisation non autorisée.
- **Politique de sécurité organisationnelle** : Elle se compose d'un ensemble de lois, de règles et de pratiques qui régissent la gestion, la protection et la distribution des ressources au sein d'une organisation afin d'atteindre les objectifs de sécurité.
- **Politique de sécurité automatisée** : C'est un ensemble de restrictions et de propriétés qui spécifient comment un système informatique se protège contre toute utilisation non conforme aux règles définies dans la politique de sécurité organisationnelle.

Politique de contrôle d'accès vs mécanisme de contrôle d'accès

Politique de contrôle d'accès

- Définit les règles, les directives et les stratégies qui régissent l'accès aux ressources d'un système informatique.
- Elle spécifie qui est autorisé à accéder à quelles ressources et dans quelles conditions.
- Elle peut inclure des directives sur l'authentification, l'autorisation, les niveaux de privilège, les restrictions d'accès et d'autres aspects liés à la sécurité de l'accès aux données et aux systèmes.

Politique de contrôle d'accès vs mécanisme de contrôle d'accès (2)

Mécanisme de contrôle d'accès :

- Le mécanisme de contrôle d'accès est l'outil ou la technologie utilisé pour mettre en œuvre et appliquer les politiques de contrôle d'accès.
- Il transforme les règles abstraites de la politique de contrôle d'accès en fonctionnalités concrètes dans le système informatique.
- Il fournit les mécanismes techniques pour vérifier l'identité des utilisateurs, appliquer les règles d'autorisation et restreindre l'accès aux ressources conformément à la politique établie.

Le contrôle d'accès

Le contrôle d'accès est un mécanisme par lequel un système informatique détermine et régule les droits d'accès des entités actives, telles que les utilisateurs, les processus ou les machines, pour accéder et effectuer des opérations sur des entités passives, comme des fichiers, des dossiers, des bases de données, etc.



Les niveaux sur lesquels le contrôle d'accès fonctionne

Niveau Application :

Les mécanismes de contrôle d'accès au niveau des applications sont des composants logiciels qui mettent en œuvre les politiques de sécurité définies pour réguler l'accès aux fonctionnalités et aux données d'une application.

Pour illustrer cela, prenons l'exemple d'une entreprise où le personnel peut être affecté à plusieurs rôles différents.

Chaque rôle représente un ensemble spécifique de responsabilités et de privilèges au sein de l'entreprise. Par exemple, un employé peut être à la fois un "utilisateur standard", un "superviseur" et un "administrateur".

Les niveaux sur lesquels le contrôle d'accès fonctionne (2)

- Chaque **rôle** peut initier plusieurs **opérations** possibles dans le système. Par exemple, un **utilisateur standard** peut avoir le droit de **consulter** les données, un **superviseur** peut avoir le droit de **modifier** certaines données et **d'approuver** des demandes, tandis qu'un **administrateur** peut avoir le droit de **créer** des comptes d'utilisateurs et de **modifier** les paramètres du système.
- Cependant, chaque opération nécessite des autorisations préalables pour pouvoir être exécutée. Ces autorisations sont définies par les politiques de sécurité de l'entreprise et sont appliquées par les mécanismes de contrôle d'accès au niveau des applications. Par exemple, un utilisateur ne peut pas modifier les données sans avoir l'autorisation appropriée, même s'il est assigné au rôle de superviseur.

Les niveaux sur lesquels le contrôle d'accès fonctionne (3)

Niveau Middleware :

- Le middleware est une couche intermédiaire située entre les applications et les ressources système sous-jacentes.
- le middleware peut être représenté par un système de gestion de base de données (SGBD), qui fournit des fonctionnalités avancées pour gérer et manipuler des données structurées de manière cohérente.
- Le SGBD met en œuvre un certain nombre de propriétés de protection, telles que l'authentification des utilisateurs, l'autorisation d'accès aux données et le chiffrement des données sensibles.

Les niveaux sur lesquels le contrôle d'accès fonctionne (4)

Niveau Système d'exploitation :

- Le système d'exploitation (OS) est une couche inférieure qui fournit les ressources de base nécessaires au fonctionnement du système, telles que la gestion des fichiers, des processus et des communications réseau.
- Il est chargé de construire les ressources de bas niveau, telles que les fichiers et les ports de communication, et de fournir les mécanismes de contrôle d'accès pour ces ressources.

Les phases d'élaboration du contrôle d'accès

L'élaboration d'un système de contrôle d'accès suit un processus en plusieurs phases, basé sur les concepts clés suivants :

Politiques de sécurité :

- Les politiques de sécurité définissent les règles de haut niveau qui régissent l'accès aux ressources et déterminent qui est autorisé à accéder à quoi afin de garantir un système sûr.
- En d'autres termes, la politique de sécurité d'un système est l'ensemble des lois, des règles et des pratiques qui régissent la manière dont les informations sensibles et les autres ressources sont gérées, protégées et distribuées à l'intérieur d'un système spécifique.

Les phases d'élaboration du contrôle d'accès (2)

Modèles de sécurité :

Les modèles de sécurité décrivent une représentation abstraite, souvent formelle, des politiques de sécurité et de leur fonctionnement. Ils facilitent la construction de preuves sur la sécurité d'un système, c'est pourquoi les efforts se concentrent souvent sur la construction de modèles pour la sécurité.

Les phases d'élaboration du contrôle d'accès (3)

Mécanismes de sécurité :

Les mécanismes de sécurité définissent les fonctions de bas niveau, à la fois logicielles et matérielles, qui mettent en application les contrôles imposés par la politique de sécurité.

La définition des politiques ne garantit pas à elle seule le bon fonctionnement du système. Les politiques mises en place peuvent générer des décisions d'accès ne traduisant pas les exigences de sécurité souhaitées. Ces politiques doivent respecter certaines propriétés essentielles pour que l'on puisse admettre que le système est sécurisé.

Anomalies dans les règles de contrôle d'accès

- **Incohérence :**

L'incohérence se produit lorsque les règles de contrôle d'accès permettent et interdisent simultanément un accès donné à une ressource. **Par exemple**, une règle peut autoriser l'accès à un dossier pour un utilisateur spécifique, tandis qu'une autre règle l'interdit pour le même utilisateur. Cette situation crée une ambiguïté et peut entraîner des comportements imprévisibles du système.

- **Incomplétude :**

Un système de contrôle d'accès est dit incomplet lorsqu'il ne fournit pas de réponse claire à une demande d'accès à une ressource. Cela peut se produire lorsqu'aucune règle ne spécifie explicitement si l'accès est autorisé ou interdit pour une demande particulière. En conséquence, le système peut être incapable de prendre une décision appropriée, ce qui peut entraîner des problèmes de sécurité ou de fonctionnement.

Anomalies dans les règles de contrôle d'accès

- **Fuite d'information :**

- Une fuite d'information se produit lorsqu'un système de contrôle d'accès divulgue des données sensibles à des utilisateurs non autorisés. Cela peut se produire si les règles de contrôle d'accès ne sont pas correctement définies ou si elles permettent un accès excessif à certaines ressources. Les fuites d'informations peuvent compromettre la confidentialité des données et entraîner des violations de la sécurité.

- **Redondance :**

- La redondance survient lorsqu'une même réponse à une demande d'accès est définie dans plusieurs règles de contrôle d'accès. **Par exemple**, si deux règles différentes accordent à un utilisateur l'accès à un fichier spécifique, cela crée une redondance. La résolution de la redondance est importante car elle permet de simplifier les règles de contrôle d'accès, de réduire la complexité du système et d'éviter les erreurs et les incohérences.

Les références

(NIST, 2013) NIST, (2013) http://www.chipestimate.com/tech_talks/2008/12/02/Certicom-ECC-Drives-Next-Generation-Hardware-Security-Applications [Consulter en juin 2013].

(Savola and Abie, 2009) Savola, R. and Abie, H. (2009) “Identification of Basic Measurable Security Components for a Distributed Messaging System”, In Proceedings of Third International Conference on Emerging Security Information, Systems and Technologies, Athens, Glyfada, pp. 121-128.

(Van Quang, 2005) Van Quang, D. (2005) “Contribution à l'étude de la qualité de service pour les protocoles sécurisés de télécommunications. Application à IPSec”, l'université Paris XII-Val Marne, [online] <http://doxa.u-pec.fr/theses/th0231084.pdf> [consulter en janvier 2012].

(Wang and Wulf, 1997) Wang, C. and Wulf, W.A. (1997) “Towards a Framework for Security Measurement”, In Proceedings of 20th National Information Systems Security Conference, Baltimore, MD, USA, pp.522-533.

(Guillot, 2013) Guillot, P. (2013) “La cryptologie : L'art des codes secrets ”, EDP sciences, France, ISBN : 978-2-7598-0811-3.

(Cole et al., 2005) Cole, E., Krutz, R., Conley, J. (2005), “Network Security Bible”, Wiley Publishing, Inc, ISBN-13:978-0-7645-7397-2.

